

■ GUIDE COMPLET DE RÉVISION & DE SOUTENANCE — BEDERJA TECHNIQUE

Architecture Zero Trust, Formule Mathématique SOAR & Supervision API Bancaire

Auteure : Dalel AKREMI | Encadrant : Dr. Akram BELAZI | Master Pro : MPSSI — ISIMG (2025/2026)

1. LE PITCH ORAL EN 1 MINUTE (Kifech t9addem rou7ek w machrou3ek)

Klem t9oulou direct lel jury (Bederja fluide w mots techniques) :

« Bonjour nass lkol. Esmi Dalel Akremi, et je vous présente mon projet de fin d'études ta7t encadrement Dr. Akram Belazi. Le projet mte3na y-implémenti une **Architecture de Sécurité Zero Trust** pour sécuriser les **APIs bancaires ouvertes** fi cadre el directive européenne **DSP2 (Open Banking)**.

B-7okm ennou el réseau bancaire ma3adech fermé kima 9bal, combinina m3a baadhhom : barrière cryptographique au niveau transport (**mTLS**), gestion centralisée des identités et des accès (**Keycloak / OAuth2 / JWT RS256**), et un automate de défense active (**SOAR**) capable bech y-bloqui ay adresse IP suspecte fi a9al men 30 secondes grâce à un score dynamique d'atténuation temporelle (**T_decay**).

Les résultats mtaa les tests kénou excellents : **0 vulnérabilité critique** sous OWASP ZAP w latence globale mtaa **72,3 ms**, ce qui respecte largement la norme DSP2 RTS (inférieure à 200 ms). »

2. L'HISTOIRE DU PROJET B-TAFSIR MOUBASSET (Contexte & Problématique)

• ■ El Banque 9bal (Modèle Château-fort / Périmétrique) : Réseau interne fermé, personne men barra ma yod5ol direct. Pare-feu f-el beb kén kény khater kol chay fel interne réputé digne de confiance.

• ■ El Banque el Youm (Directive DSP2 / Open Banking) : Loi européenne t-forci les banques bech y-7ellou des APIs lel prestataires tiers (TPP : Third Party Providers kima Flouci, PayPal, applications de budget).

• ■■ El Problème el Kbir : Les attaquants walew y-staghllou nafs les APIs ouvertes hedhom (BOLA, Injections NoSQL, Force Brute, vol de sessions).

• ■■ El 7all Zero Trust (NIST SP 800-207) : Mabda « Ne jamais faire confiance, toujours vérifier » (Never trust, always verify). Hatta fi wosst el réseau interne, kol requete lezemha authentication, autorisation, w vérification cryptographique continue.

3. LES 3 GARDIENS DU SYSTÈME (Fonctionnement Multicouche)

1. Le Vigile f-el Bèb — NGINX (Passerelle mTLS / Reverse Proxy) : Point d'entrée unique (ports 80/443). Y-talab certificat client X.509 signé par la PKI interne pour chaque TPP (Mutual TLS). Eli ma 3andouch certificat yetrejjet direct fi DMZ b-code HTTP 400. Y-applique zeda rate limiting (10 req/s) w y-thabbet f-el variable X-Real-IP.

2. Le Guichet d'Identité — Keycloak (Serveur IAM certifié OIDC / OAuth2) : Authentification forte à double facteur (2FA OTP Email / TOTP). Y-livri jeton d'accès **JWT asymétrique signé en RS256** (b-clé privée RSA) valable 15 minutes fih les rôles RBAC.

3. La Salle du Coffre — FastAPI (Backend Bancaire Asynchrone) : Y-valisi el JWT de façon 100% autonome w stateless grâce lel clé publique mtaa Keycloak. Y-valisi les entrées b-Pydantic (typage Decimal pour éviter les arrondis d'argent), y-stocki fi **MongoDB** w ma y-stockich el CVV mtaa les cartes (conformité PCI-DSS).

4. LA SEGMENTATION RÉSEAU ZERO TRUST (4 Réseaux Docker Étanches)

Réseau Docker	Zone de Sécurité	Composants & Rôle	Niveau d'Isolation
frontend_tier	DMZ (Périmètre externe)	Passerelle NGINX. Reçoit le trafic client.	Seul réseau exposé sur Internet (Ports 80/443).
backend_tier	Zone applicative privée	FastAPI, Keycloak, Threat Monitor, SecurityState, Redis.	Totalement privé, accessible uniquement men NGINX.
data_tier	Cœur de persistance	MongoDB (Core Banking) + PostgreSQL (IAM Keycloak).	internal: true (aucun accès direct men barra).
monitoring_tier	Zone SOC / Supervision	Filebeat, Logstash, Elasticsearch, Kibana (SIEM).	Réseau isolé dédié lel collecte w analyse des logs.

5. KIFECH MONGODB W POSTGRESQL YCOMMUNIQUEW MAA BAADH-HOM ? (EL SUJET EL ASESSI !)

■ Réponse décisive lel jury (À retenir par cœur) :

« Madame, **PostgreSQL w MongoDB ma ycommuniquewch direct bin b3adh-hom** (aucun lien direct DB-to-DB, ma fammech requête SQL-to-NoSQL). Hedha un choix architectural volontaire pour respecter le principe de **Découplage (Decoupling)** et de **Moindre Privilège (Least Privilege)**. »

Kifech el architecture m9asma (Polyglot Persistence) :

- **PostgreSQL 15 (IAM & Authentication)** : Base relationnelle ACID khassa exclusivement b-**Keycloak**. Te5dem m3a les tables hautement normalisées : utilisateurs, mots de passe hashés (Argon2/PBKDF2), rôles RBAC, sessions, consentements OAuth2.
- **MongoDB 7 (Core Banking Métier)** : Base documentaire NoSQL khassa b-**FastAPI**. Te5dem m3a les comptes bancaires, transactions, soldes, devises, honeytokens, w logs d'audit bancaires.

Kifech el communication tsir (Le Pont Stateless via JWT RS256) :

- Étape 1 (Login)** : Le client yodkhol ya3mel login 3la Keycloak (username + password + 2FA). Keycloak y-thabbet mel données fi PostgreSQL.
- Étape 2 (Token Generation)** : Keycloak y-généri **Access Token JWT** signé b-clé privée **RSA (RS256)** fi l'identifiant standard sub (Subject ID / UUID).
- Étape 3 (API Request)** : Le client yeb3ath la requête bancaire lel FastAPI m3a l'en-tête Authorization: Bearer <Token>.
- Étape 4 (Stateless Verification)** : FastAPI t-vérifi el signature mtaa el JWT b-clé **publique** mtaa Keycloak. **FastAPI ma ta3mel 7atta requête vers PostgreSQL ni vers Keycloak !** (Zéro latence, validation instantanée en mémoire).
- Étape 5 (Requête Métier)** : FastAPI t-extrayi l'identifiant user_id mel champ sub, w temchi t-interrogi la collection accounts ou transactions fi MongoDB.

■ **Fayedha Sécuritaire** : Découplage total ! Ken l'API FastAPI tet-pirata ou MongoDB yet-ta9ra, la base maîtresse PostgreSQL to93od complètement inaccessible w protégée.

6. LA FORMULE MATHÉMATIQUE DU SCORE SOAR & EXPLICATION COMPLÈTE EN DÉTAILS

■ Équation du Score Dynamique de Menace à Atténuation Temporelle (Temporal Decay) :

$$T_decay(x, t) = T(x, t_last) \cdot e^{(-\lambda \cdot \Delta t)} + w(e_current)$$

■ Tafsir Kol Variable w Symbole bel Behi (Mots Techniques & Bederja) :

- **x** : L'adresse IP mtaa el client ou le service TPP connecté (identifiée avec certitude via X-Real-IP certifié par NGINX).
- **t** : Le timestamp actuel (temps en secondes au moment mtaa l'événement / la requête en cours).
- **t_last** : Le timestamp mtaa l'erreur el 9dima eli 3malha nafs l'IP x.
- **Δt = (t - t_last)** : L'intervalle de temps (délai en secondes) el fari9 bin el requete hedhi wel requete l'9dima.
- **T(x, t_last)** : Le score de menace l'9dim eli kén msajjel fi mémoire 3and l'IP x.
- **λ (Lambda)** : Le **coefficient d'atténuation temporelle** (Decay rate). Yethseb b-la formule :

$$\lambda = \ln(2) / T_half = \ln(2) / 120 \approx 0,0057762 \text{ s}^{-1}$$
- **T_half = 120 secondes (2 minutes)** : La **demi-vie (Half-life)** kima la loi de désintégration radioactive en physique ! Ma3neha ba3d 120s men ghir 7atta erreur, le score mtaa l'IP yti7 l-chhtar (50%) automatiquement.
- **e^(-λ · Δt)** : Le **facteur d'atténuation exponentielle** :
 - Idha Δt **sghir barcha** (attaquant ybardi fi des requêtes wara b3adhom fi 2 ou 3 secondes) : $e^{(-\lambda \Delta t)} \approx 1$. El score l'9dim ma yti7ch w yzid yettla3 b-surveillance maximale !
 - Idha Δt **kbir** (client 3adi 93ad 5 ou 10 minutes) : $e^{(-\lambda \Delta t)} \rightarrow 0$. El score l'9dim yetfassa5 bit-tadrig w yarja3 lel sfer (Anti Faux-Positifs).
- **w(e_current)** : Le **Poids (Weight)** mtaa l'erreur en cours selon la gravité de l'événement :
 - **w(401 / 422) = 1,0** : Tentative de Force Brute / mot de passe ghalet / payload malformé (Gravité Haute).
 - **w(403) = 0,7** : Accès refusé / sonde de faille **BOLA** pour accéder au compte d'autrui (Gravité Moyenne-Haute).
 - **w(429) = 0,5** : Dépassement du Rate Limiting NGINX / flood de requêtes (Gravité Moyenne).
- **S = 3,0 (Seuil Critique / Critical Threshold)** : Dès que $T_decay(x, t) \geq 3,0$, le système SOAR y-déclenchi alerte temps réel SSE w y-lansi compte à rebours de 30s avant **blocage définitif de l'IP fi Redis et iptables**.

■ Exemple Concret Chiffré pour Convaincre le Jury :

• Cas Attaque (Force Brute rapide) :

1. $t = 0s$: 1ère erreur 401 $\rightarrow T = 0 + 1,0 = 1,0$
2. $t = 3s$ ($\Delta t = 3s$) : 2ème erreur 401 $\rightarrow T = (1,0 \cdot e^{(-0,005776 \cdot 3)}) + 1,0 = (1,0 \cdot 0,9828) + 1,0 = 1,983$
3. $t = 6s$ ($\Delta t = 3s$) : 3ème erreur 401 $\rightarrow T = (1,983 \cdot 0,9828) + 1,0 = 1,949 + 1,0 = 2,949$
4. $t = 8s$ ($\Delta t = 2s$) : 4ème erreur 401 $\rightarrow T = (2,949 \cdot 0,9885) + 1,0 = 2,915 + 1,0 = 3,915 > 3,0$

■ **RÉSULTAT : Seuil S=3,0 dépassé fi 8 secondes → Alerte SSE + Blocage Immédiat de l'Attaquant !**

• Cas Client Légitime (Faute de frappe innocente) :

1. $t = 0s$: Le client ghlot fi mot de passe (401) $\rightarrow T = 1,0$.
2. Le client ya93ad 5 minutes (300 secondes) bech yetfakkor el mot de passe mte3ou ($\Delta t = 300s$).
3. Calcul de décroissance : $e^{(-0,005776 \cdot 300)} = e^{(-1,7328)} \approx 0,1768$.
4. $t = 300s$: yod5ol ya3mel faute okhra 401 $\rightarrow T = (1,0 \cdot 0,1768) + 1,0 = 1,177$.

■ **RÉSULTAT : 1,177 < 3,0 → Le client MA YETBLOQUECH ! Taux de faux positifs = 0 %.**

7. KIFECH BDIT EL KHEDMA W KIFECH 3MALT EL PARTITIONNEMENT DES TÂCHES ?

Kifech tjaweb el profa 3la el méthodologie (Security by Design & WBS) :

« Bdit el khedma b-démarche **Security-by-Design** w **Shift-Left**. Ma mchitch direct n-codi les endpoints FastAPI, mais 9ssamt el khedma 3la **5 axes majeurs** : »

- **Axe 1 — Analyse des exigences & Threat Modeling (STRIDE)** : Dirassat les normes Open Banking (DSP2 / RTS), standard **FAPI 1.0 Advanced**, wel cadre **NIST SP 800-207 Zero Trust**. Modélisation mtaa les 6 menaces STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege).
- **Axe 2 — Architecture & Segmentation Réseau** : Conception mtaa les frontières de confiance w configuration mtaa Docker Compose b-4 réseaux virtuels étanches (DMZ, Backend, Data, Monitoring).
- **Axe 3 — Socle Cryptographique & IAM** : Déploiement NGINX m3a terminaison mTLS (certificats X.509 pour les TPP), instantiation Keycloak 3la PostgreSQL m3a OAuth2/OIDC, PKCE, 2FA, w génération des JWT RS256.
- **Axe 4 — Core Banking API & Automate SOAR** : Développement de l'API FastAPI asynchrone, validation Pydantic (typage Decimal), middleware d'audit, algorithme dynamique T_decay w notifications temps réel SSE.
- **Axe 5 — Métrologie, Validation & DAST** : Tests de charge (latence 72,3 ms, débit 465 req/s), simulations d'attaques et audit automatisé OWASP ZAP (0 vulnérabilité).

8. 3LECH KHTART KOL COMPOSANT W KOL MOYEN DE SÉCURITÉ ? (Tableau Justificatif)

Composant / Techno	Alternative Écartée	Raison Technique & Bénéfice de Sécurité (Bederja & Mots Techniques)
FastAPI (Python 3.10)	Flask, Django REST	Performance asynchrone ASGI (Starlette/Uvicorn) + validation automatique stricte b-Pydantic à l'ingestion (immunité contre le Mass Assignment w type injection).
NGINX + mTLS	HTTPS classique simple	Authentification mutuelle forte X.509 pour chaque TPP. L'intrus yet-rejeta direct fi DMZ sans toucher l'API. Réécriture sécurisée mtaa X-Real-IP.
Keycloak 24	Système auth maison	Serveur IAM certifié OIDC / FAPI 1.0. Gestion native 2FA (OTP/TOTP), RBAC w séparation totale bin l'identité wel code métier.
JWT RS256 (Asymétrique)	HS256 (symétrique) ou Tokens opaques	Clé privée chez Keycloak pour signer, clé publique chez FastAPI pour vérifier. Validation stateless ultra-rapide sans surcharger la base de données.
PostgreSQL 15	MySQL, SQLite	ACID transactionnel strict w gestion rigoureuse des tables d'utilisateurs normalisées requises par Keycloak.
MongoDB 7	Bases SQL classiques	Modèle documentaire JSON/BSON flexible pour l'Audit Trail et transactions multi-documents bancaires avec typage Decimal strict.
Redis 7	Mémoire interne Python	Magasin clé-valeur in-memory distribué sub-milliseconde. Y-synchronisi l'état des IP bloquées (SecurityState) et le Rate Limiting (Token Bucket).
Moteur SOAR (T_decay)	SIEM passif classique	Défense active autonome : calcul du score de menace en mémoire et blocage de l'IP hostile fi a9al men 30s sans intervention humaine.

9. LES QUESTIONS PIÈGES DU JURY & RÉPONSES TYPES DÉTAILLÉES

■ Question 1 : « 3lech ma sta3malthch un simple WAF (Web Application Firewall) wahdou ? »

Réponse Bederja : Un WAF classique ye5dem b-signatures statiques (regex). Ynajjim y-fi9 b-injection SQL standard amma **ma ynajjimch y-detecti les failles de logique métier** kima el **BOLA** (win utilisateur connecté de façon légitime y-baddel l'ID mtaa compte client ekher f-el URL). El solution mte3na t-combiner validation métier stricte fi FastAPI m3a corrélation comportementale SOAR fi temps réel.

■ Question 2 : « Un attaquant vnaiimchi y-zouwer l'IP mte3ou b-l'en-tête X-Forwarded-For ? »

Réponse Bederja : La, impossible ! Khater n-appliquiw le principe Zero Trust : on ne fait jamais confiance aux en-têtes mtaa el client. F-el DMZ, NGINX y-ecrasi systématiquement l'en-tête X-Real-IP b-l'IP réelle mtaa la socket TCP (\$remote_addr). Hédhi hiya l'adresse certifiée eli toussel lel Threat Monitor.

■ Question 3 : « Est-ce que un code HMAC ou un fichier append-only y-dhammen la non-répudiation des logs bancaires ? »

Réponse Bederja : La ! Le HMAC est symétrique : ay we7ed 3andou la clé secrète (hatta admin interne compromis) ynajjim y-recalcli des HMAC valides l-des logs mbadlin. Pour une vraie **non-répudiation juridique** (normes PCI-DSS / ISO 27001), lezem : (1) Chaînage cryptographique unidirectionnel (Merkle Hash Chain SHA-256), (2) Signature asymétrique scellée dans un boîtier matériel durci (**HSM**), (3) Horodatage qualifié RFC 3161 (TSA), et (4) Stockage immuable **WORM** (Write Once Read Many).

■ Question 4 : « 3lech sta3malth tvpage Decimal f-Pvdantic w ma sta3malthch Float 3adi ? »

Réponse Bederja : F-el informatique, les nombres float ye5dmou b-norme IEEE 754 binaire w ya3mlou des erreurs d'arrondi (par exemple $0.1 + 0.2 = 0.30000000000000004$). F-domaine bancaire, el erreurs hedhom ynajjmou y-sabou des pertes financières ou attaques d'arrondi (salami slicing). Decimal y-garanti précision exacte au centime près.

10. LES CHIFFRES CLÉS DU PROJET (À retenir par cœur)

Métrique	Valeur Mesurée	Norme / Référence	Fayda & Signification pour le Jury
Latence totale API	72,3 ms	SLA DSP2 RTS (< 200 ms)	API ultra-rapide, garantie de parité de service légale.
Débit saturé (c=35)	465 req/s	Loi de Little ($X = N / R$)	Capacité d'absorption élevée sous forte charge concurrente.
Surcoût Threat Monitor	4,2 ms	Middleware asynchrone	Impact imperceptible 3la l'expérience utilisateur.
F1-Score SOAR	98,51 %	N = 1000 sessions	Précision 98,02% et Rappel 99,00% (très faible taux de faux positifs).
Délai de réaction SOAR	< 1 seconde	Calcul en mémoire	Détection instantanée et mitigation automatique rapide.
Audit OWASP ZAP (DAST)	0 High, 0 Medium	OWASP API Top 10	Preuve formelle d'immunité contre BOLA, Injection et Broken Auth.

11. PLAN DE PRÉSENTATION DIAPOS POUR LE JOUR J (12 Slides / 15-20 Minutes)

Diapo	Titre de la Diapositive	Ce qu'il faut dire au Jury (Bederja Technique)
1	Titre & Présentation	Présentation personnelle, encadreur Dr. Akram Belazi, intitulé du PFE.
2	Contexte : DSP2 & Open Banking	Obligation légale d'ouverture des APIs bancaires aux TPP et augmentation des risques.
3	Problématique & Objectifs	Comment ouvrir les APIs sans créer de failles ? Paradigme Zero Trust (NIST SP 800-207).
4	Architecture Globale & Réseaux	Les 4 réseaux Docker étanches (DMZ NGINX, Backend privé, Data interne, Monitoring).
5	Barrière mTLS & OAuth2 / FAPI	Certificat X.509 obligatoire pour chaque TPP et délégation de consentement.
6	Authentification Forte 2FA (SCA)	Double facteur OTP Email (nominal) et TOTP smartphone (alternatif).
7	Persistence Polyglotte (Postgres/Mongo)	PostgreSQL pour l'IAM Keycloak vs MongoDB pour le Core Banking, pont stateless JWT RS256.
8	Innovation : Automate SOAR & Formule	Formule du score T_{decay} , atténuation temporelle exponentielle et seuil critique $S = 3,0$.
9	Validation : Audit OWASP ZAP	Preuve de sécurité : 0 vulnérabilité critique détectée sur l'ensemble des endpoints.
10	Banc d'Essai de Performance	Latence moyenne 72,3 ms (largement conforme au SLA < 200 ms) et débit 465 req/s.
11	Démonstration & Dashboard	Dashboard Kibana, réception des alertes temps réel SSE et blocage effectif de l'IP.
12	Conclusion & Perspectives	Bilan du prototype et perspectives industrielles (Redis distribué, eBPF, Kubernetes).

12. GLOSSAIRE EXPRESS DES MOTS TECHNIQUES

- **Zero Trust** : Philosophie de sécurité : « *Ne jamais faire confiance, toujours vérifier* ».
- **mTLS (Mutual TLS)** : Terminaison chiffrée où le serveur et le client présentent chacun un certificat X.509.
- **JWT RS256** : Jeton JSON Web Token signé b-cryptographie asymétrique (clé privée pour signer, clé publique pour vérifier).
- **BOLA (Broken Object Level Authorization)** : Faille numéro 1 OWASP API win un attaquant manipule un ID f-l'URL pour voir le compte d'un autre.
- **SOAR** : Automate de sécurité capable d'orchestrer et de bloquer une menace en temps réel sans humain.
- **T_{decay}** : Score dynamique de menace b-atténuation temporelle exponentielle pour éliminer les faux positifs.